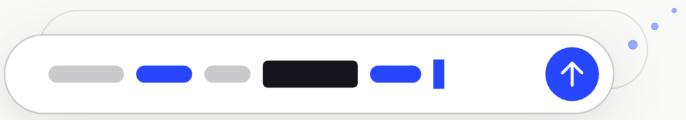


Everything you type can become someone else’s data.

Prompts are the most honest record of who we are — and an open, under-defended research problem.

Online, you perform.
To AI, you confess.

WHAT HE POSTS · INSTAGRAM

“new apartment finally set up.
Seoul life begins.
#SeoulLife #NewPlace
#Adulting #Blessed”

curated · for an audience · every word chosen

WHAT HE PROMPTS · SAME NIGHT

“my rent is ₩1.45M next week
and my card payment bounced.
what happens if i miss the card
payment by a few days?”

candid · unsent · logged, rarely deleted

And it is the dominant interface: ~900M weekly users[1], ~2.5B prompts/day[2], with roughly one in four workplace prompts sensitive.[3][4]

[1] ChatGPT WAU ’26 [2] 2.5B prompts/day [3] Cyberhaven ’25 [4] Shadow-AI ’25

The threat model.

The provider & insiders	retention, secondary use, staff & subprocessor access [5]
Attackers	breach, misconfig, stolen credentials, prompt injection [6] [7]
Brokers & advertisers	behavioural targeting from aggregated prompts
Governments	subpoenas, legal holds, surveillance requests [8]
People close to you	a shared or unlocked device
Future models	a model that memorised your data, queried by someone else [9]

One prompt, many adversaries — and the user controls almost none of them.

[5] Anthropic terms [6] Wiz 38TB ’23 [7] EchoLeak ’25 [8] OpenAI v. NYT [9] Nasr et al. ’23

It has already happened — repeatedly.

2021	Mar ’23	Apr ’23	Sep ’23	Jan ’25	Aug ’25
Lee Luda	**Redis bug**	**Samsung**	**MS 38TB**	**DeepSeek**	**AgentFlayer**
9.4B chat logs → real names, bank #s [10]	payment data shown to strangers [11]	source code pasted in; AI banned [12]	one token exposed 38TB [6]	>1M log lines: chats + keys [13]	0-click via connectors [14]

From chatbots to agents — every era brought a new way for prompts to leak.

[6] Wiz 38TB ’23 [10] Lee Luda ’21 [11] Redis bug, OpenAI ’23 [12] Samsung ban ’23 [13] DeepSeek leak ’25 [14] AgentFlayer ’25

Measured, not hypothesized.

77%
of AI users paste company data into chatbots [4]

27%
of RAG chats leak a secret (benchmark) [16]

€15M
first GDPR fine for generative AI [17]

96%
prompt-injection success, pre-defense [15]

150×
more memorized data extracted from ChatGPT [9]

$670K
added breach cost involving “shadow AI” [18]

Independent studies and benchmarks converge on the same conclusion.

[4] Shadow-AI ’25 [9] Nasr et al. ’23 [15] Agent injection ’25 [16] PrivacyBench ’25 [17] Garante €15M ’24 [18] IBM breach ’25

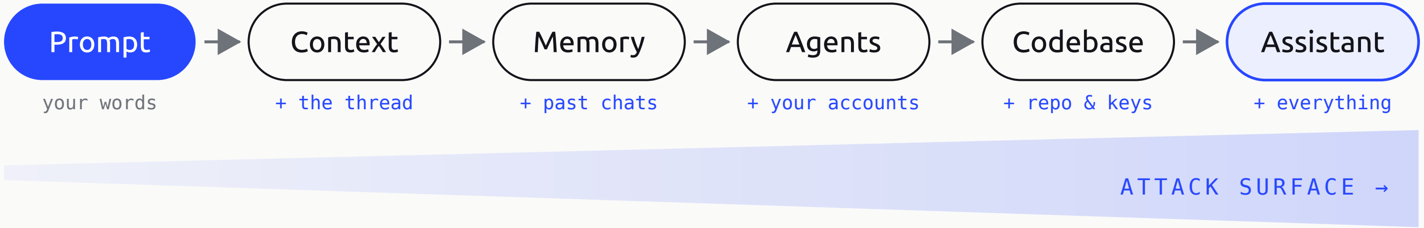
By default, your chats train the next model.

Anthropic	30-day retention — up to 5 years if you allow training [5]
OpenAI	a court order forces it to preserve even deleted chats; ~20M logs at issue in the NYT case [8] [19]
Google Gemini	human-reviewed, kept up to ~3 years [20]
“Synthetic” data is no shield	fine-tuning on AI-generated data still leaks source PII (~44% more extractable) [21]

Retention is the default; deletion is the exception — and the data outlives the chat.

[5] Anthropic terms [8] OpenAI v. NYT [19] OpenAI 20M logs [20] Gemini privacy [21] Akkus, USENIX ’25

It leaves your hands — and the surface only grows.



Five leakage surfaces, each its own research problem: context/RAG[16], memory[22], training & retention[5][8], agents[14], and coding tools[23].

[5] Anthropic terms [8] OpenAI v. NYT [14] AgentFlayer ’25 [16] PrivacyBench ’25 [22] CAPRI, IEEE ’25 [23] CamoLeak ’25

Why current defenses fall short.

Redaction	redact less and residue re-identifies; redact more and you lose the context the model needs [24] [25]
Pseudonymization	needs a persistent fake ↔ real map — itself a honeypot, and drift across turns re-links identity [22]
Homomorphic encryption	no major provider offers it, and it's far too slow and costly to run [26]
Confidential computing	enclave the provider can't read — trust & supply-chain caveats [27] [28]
On-device / local LLMs	never send raw data — but smaller models reason worse [29]
Federated learning	train without pooling — niche for everyday prompting [24]

Three failure modes recur: protection that costs capability, breaks meaning, or still re-links identity.

[22] CAPRI, IEEE '25 [24] Edemacu survey '25 [25] ACL '25, re-link [26] Preempt '25 [27] Conf. compute '24 [28] Apple PCC [29] Rescriber, CHI '25

The research frontier.

Efficient private prompting	protection without heavy crypto or local-only models [26]
Meaning-preserving sanitization	hide who it is, keep what it says [25]
Lightweight detection	accurate PII & secret spotting, on the edge [29]
Memory- & conversation-aware privacy	consistent across turns and profiles [22]
Retrieval-aware privacy	keep RAG from surfacing private context [30]
Agent guardrails	least-privilege + system-level egress control [15]
Shared benchmarks	so methods are comparable and provable [16]

Open directions, building on the privacy-prompting literature. [24]

[15] Agent injection ’25 [16] PrivacyBench ’25 [22] CAPRI, IEEE ’25 [24] Edemacu survey ’25 [25] ACL ’25, re-link [26] Preempt ’25 [29] Rescriber, CHI ’25 [30] Retrieval privacy ’25

Our preliminary work.

The field is heading toward on-device pseudonymization — so we built one, and measured it honestly.

We built the data real prompts need.

Existing PII datasets are mostly single-turn and narrow. Real prompts are multi-person and multi-turn — so we generated a corpus that looks like them.

12,283
synthetic conversations

26,616
conversation turns

112,321
labelled PII mentions

21,440
distinct person-mentions

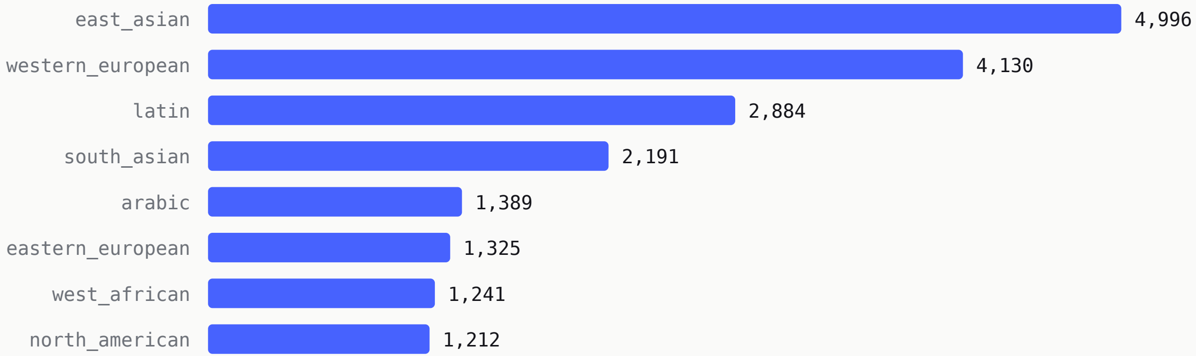
250
multi-turn dialogues (5–15 turns each)

36
cultural origins · 16 world regions

Larger single-turn sets exist — pii-masking-300k[34] and Nemotron-PII[35] — but neither is multi-turn or multi-person.

Built for the world’s messiness, not a template.

CULTURAL ORIGIN PERSON-MENTIONS · TOP 8 OF 36



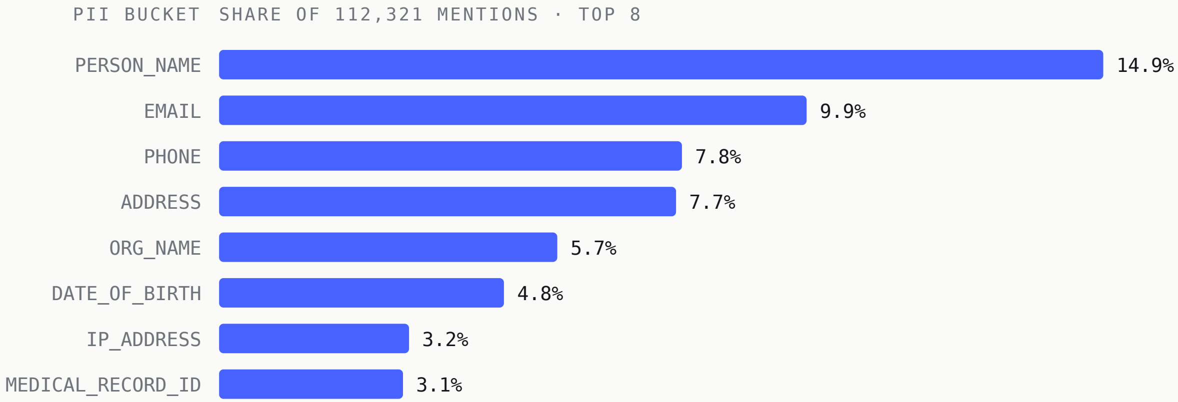
36 cultural origins in all; 16 world regions kept near-uniform (~611–672 samples each — USA, China, India, Korea, Brazil, Japan, Nordic, Middle East, Sub-Saharan Africa…). 60.7% of samples name two or more people.

Registers that look like real work.

plain chat · voice-to-text w/ typos	how people actually type — messy, unpunctuated, mid-thought
email draft · formal letter · form paste	copied-in structure carrying names, addresses, IDs
.env contents · shell session	secrets, hostnames, tokens pasted straight from a terminal
YAML / JSON config w/ secrets	the exact stack-trace-and-key paste from the walkthrough
density & obfuscation seeded	PII load low → very-high; 38.7% clean, rest partial / informal / inline-code

Sampled across AWS/GCP/Azure, Linux/macOS/Windows, and industries from fintech to healthcare — so detectors can't win by memorising one format.

112,321 mentions, one action each.



Each entity is also assigned an action — pseudonymize 87.3% · hard-redact 6.5% · abstract 4.9% · suppress 0.8% · passthrough 0.4% — and a risk tier: medium 60.9% · high 29.7% · low 9.4%.

Extending it deeper — with a second generator.

1,886
conversations extended into deeper dialogues

15,088
new turns (uniform 10 per record: 2 inherited + 8 new)

13,949
new-turn PII mentions

89.4%
pseudonymize · risk medium 70.5% / high 18.7%

Generated with a different model — NVIDIA NIM (deepseek) vs the primary corpus's Gemini, as a robustness check. A separate build, not folded into the primary totals; its verification has barely started (27 verdicts — not yet representative).

One vocabulary, two layers — 100% mapped.

A corpus-native taxonomy — 2,151 fine types → 111 L1 buckets → 52 families — plus a benchmark canonical-14 (42 families · 54 L1) so any detector scores fairly. All 112,321 mentions map, 0 unmapped.

CANONICAL CLASS	SHARE	CANONICAL CLASS	SHARE
PERSON_NAME	18.3%	SECRET	7.0%
HEALTH_BIO	12.7%	DATE_TIME	6.6%
DIGITAL_ID	10.1%	FINANCIAL	5.4%
EMAIL	9.9%	GOV_ID	2.2%
ORG_PROFILE	9.7%	USERNAME	1.4%
ADDRESS	8.6%	VEHICLE_ID	0.1%
PHONE	7.8%	SENSITIVE_ATTR	<0.1%

The benchmark taxonomy is generated from the corpus file and pinned by a SHA-256 drift-guard — scoring can’t silently diverge from the data.

Every sample gated, not just scored.

57.8% / 61.9%
first-pass verifier keep-rate, two-turn builds

92.4%
keep-rate, multi-turn build

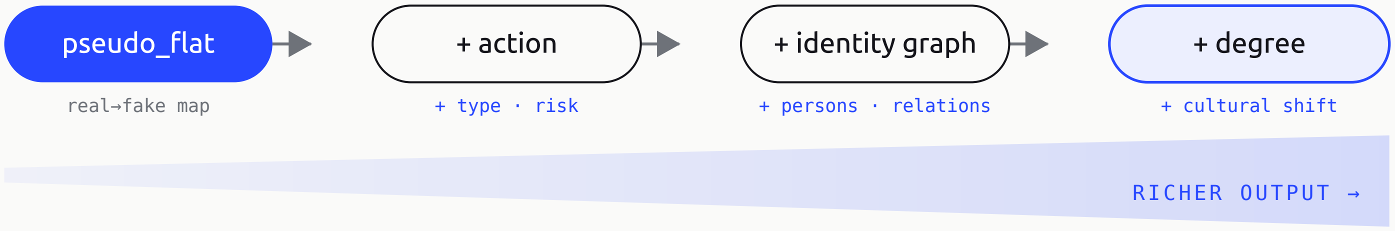
~9.3–9.9
average verifier score (of 10)

categorical
one worst-tier dimension hard-fails a sample

A high average doesn’t save a sample: the gate is categorical, not a threshold. Rejects are routed to repair or human review — they don’t enter training.

One small model, many privacy tasks.

A single 0.6–1.7B model, switched by a control token, does detection (detect / pii_screen / redact) and a reversible-pseudonymization ladder — emitting real→fake mappings the caller applies and can reverse.



pseudo_flat

Adds: nothing — the base. A flat real→fake map.

INPUT · SAME NIGHT

“i’m Min-jun, DOB 1988/03/25, +82-10-1234-5678, minjun@naver.com — book a cardiology appt.”

Given the text and any active mappings, emit new real→fake pairs. No types, no actions — the caller applies them and can reverse them.

MEMORY_DELTA


```
{
  "Min-jun": "Jiwoo",
  "1988/03/25": "1991/07/14",
  "+82-10-1234-5678": "+82-10-9876-5432",
  "minjun@naver.com": "jiwoo@naver.com"
}
```

pseudo_action

Adds: a **type** and an **action** per entity (+ context-loss-risk when true).

INPUT · SAME NIGHT

"…and my medical record is MRN-4471-KR."

MEMORY_DELTA


```
[
  {"real":"Min-jun","fake":"Jiwoo","type":"PERSON_NAME","action":"pseudonymize"},
  {"real":"MRN-4471-KR","fake":"MRN-9902-KR","type":"MEDICAL_RECORD_NUMBER",
   "action":"pseudonymize","context_loss_risk":true}
]
```


context_loss_risk is emitted only when true — a load-bearing record flags that a fake could break the task.

pseudo_graph

Adds: an **identity envelope** — each entity attaches to a person; persons carry relations.

INPUT · SAME NIGHT

“my wife will come with me — her email is yuki@…”

Discovers persons, attaches every entity via person_ref, and keeps Min-jun’s fake stable across turns.

MEMORY_DELTA


```
{ "pii_entities":[
   {"real":"Yuki","fake":"Akiko","type":"PERSON_NAME",
    "action":"pseudonymize","person_ref":"Yuki"} ],
  "persons":{ "Yuki":{"id":1,"gender":"female",
    "relationships":{"Min-jun":"spouse"}} } }
```

pseudo_flat_degree

Adds: degree control — deg = { d, tgt }; the caller pre-resolves the target region.

INPUT · SAME NIGHT

deg = { "d": 2, "tgt": "western_european" }

At d=2 the model generates fakes for a named target region (Korea → western). Lite tier is capped at $d \in \{0,1,2\}$.

MEMORY_DELTA


```
{
  "Min-jun": "Lukas Weber",
  "+82-10-1234-5678": "+49-151-2345-6789"
}
```

pseudo_graph_degree

Adds: per-person degree — deg = { s, tp }; self and third parties shift independently.

INPUT · SAME NIGHT

deg = { "s": 3, "tp": 1 }

Self degree 3 shifts east-Asian → a western identity cross-continentally, and flags every self-entity context_loss_risk:true.

MEMORY_DELTA


```
{ "pii_entities":[
   {"real":"Min-jun","fake":"James Miller","type":"PERSON_NAME",
    "action":"pseudonymize","context_loss_risk":true,
    "person_ref":"Min-jun"} ] }
```

Spotlight: when a fake would break the task.

Some values are load-bearing — the prompt is literally about them. The model flags those so a fake can't silently corrupt the answer.


```
{"real":"MRN-4471-KR","fake":"MRN-9902-KR",
 "type":"MEDICAL_RECORD_NUMBER","action":"pseudonymize",
 "context_loss_risk":true}
```


context_loss_risk fires at any degree, decoupled from cultural shift — the caller can pass such an entity through or route it to a human.

Spotlight: abstract, don’t fake.

A fake date keeps a precise, wrong value. Abstraction keeps the useful signal and drops the identifying precision.


```
{"real":"1988/03/25","type":"DATE_OF_BIRTH",
 "action":"abstract","abstract_phrase":"in his late thirties"}
```


The downstream model still knows the age band it needs — it just never sees the exact birth date.

Spotlight: privacy as a dial.

One knob (degree) trades privacy for utility, set per person by the caller.

degree 1 · same region	Min-jun → Jiwoo (Korean) · clr false
degree 3 · cross-continent	Min-jun → James Miller · clr true
degree 4 · maximum shift	Min-jun → Astrid Larsen (region + gender flip)
degree 5 · full anonymization	Min-jun → [PERSON_NAME]

Higher degree = harder to re-identify, lower utility. The dial is the reason a fixed-locale detector can’t compete.

Spotlight: it tracks who, not just what.

Entities attach to people, and people carry relations — so a re-mention never becomes a fresh, inconsistent fake.

```
"persons":{
  "Min-jun":  {"id":0,"is_self":true},
  "his wife": {"id":1,"relationships":{"Min-jun":"spouse"}},
  "Dr. Park": {"id":2,"relationships":{"Min-jun":"patient"}} }
```

"Min-jun" → "my husband" → "he" across turns all resolve to one node — the person graph a flat detector has no concept of.

Baseline failure → pseudo-task fix.

Re-detects each turn → a fresh, inconsistent fake	→ pseudo_graph + caller state · one stable fake
No concept of a person	→ pseudo_graph · persons, person_ref
Fixed locale, no cultural dial	→ pseudo_flat_degree / pseudo_graph_degree
Every span treated identically	→ action + context_loss_risk
Substitutes a fake DOB	→ action: abstract
Threshold-only no-PII handling	→ pii_screen

The detect-then-substitute floor (B0) fails on exactly the axes the task ladder was built for.

One conversation, kept consistent.

turn 1 “my name is Min-jun, email minjun@…, phone +82-10-…”
›

→ modelMIN-JUN → JIWOO · BUILDS PERSON #0 (IS_SELF)

turn 2 “my wife’s DOB is 1988/03/25, her email is …”
›

→ modelWIFE → PERSON #1 (SPOUSE); MIN-JUN STILL JIWOO; DOB → “IN HER LATE THIRTIES”

The same fake persists across turns (cross-turn consistency), a person graph forms, and a load-bearing DOB is abstracted, not faked — three things a detector can’t do.

Measured against the systems it aims to replace.

ID	SYSTEM	CLASS	REF
B0	Off-the-shelf detect + substitute (GLiNER-PII + Faker/LLM/index)	reversible	—
B0·pub	Casper · Rescriber (published browser gatekeepers)	reversible	[36] [29]
B1	CAPRI — local gatekeeper, consistent pseudonymization	reversible	[22]
B2	LLM Gatekeeper — lightweight dual-model filter	reversible	[37]
B3	RUPTA — utility-preserving anonymizer	non-reversible	[25]

Reversibility is the dividing line: B0–B2 are reversible pseudonymizers scored on leakage + mapping; B3 anonymizes and never restores, so it’s compared only on re-identification + utility. Detectors benchmarked include GLiNER[38] and Presidio[39]; related work ProSan[40], PromptGraph[41].

[22] CAPRI · IEEE Access ’25 [25] RUPTA · ACL ’25 [29] Rescriber · CHI ’25 [36] Casper · arXiv ’24 [37] LLM Gatekeeper · arXiv ’25 [38] GLiNER · HF ’24
[39] Presidio · Microsoft [40] ProSan · arXiv ’24 [41] PromptGraph · arXiv ’26

No off-the-shelf detector is production-safe.

Strict-span F1 (exact start,end,label) on four datasets. GLiNER wins on its own training distribution and collapses everywhere else; zero-shot Qwen3-4b is the only thing that holds up cross-dataset — and still isn't safe.

DETECTOR	NEMOTRON	PII-300K	PROMPT-V3	FAKER
gliner_pii	**0.902**	**0.660**	**0.282**	**0.296**
presidio	0.442	0.373	0.349	0.740
regex_rules	0.341	0.248	0.300	0.497
openai_pf	0.226	0.316	0.155	0.226
qwen3-1.7b (0-shot)	0.394	0.560	0.552	0.839
qwen3-4b (0-shot)	**0.574**	**0.717**	**0.697**	**0.882**
qwen3-8b (0-shot)	0.590	0.666	0.688	0.877

> **Leak rate stays high across the board** — on prompt-v3 **every model misses PII in ≥63% of documents**; the best cell (GLiNER on its home set) still leaks on 32%. Nothing here is safe alone.

Early signal — and what's still open.

0.28 → 0.92
Qwen3-0.6B, fine-tuning lift (indicative [42])

0.55 → 0.93
Qwen3-1.7B, fine-tuning lift (indicative)

~3.3–4.3 GB
QLoRA 4-bit training footprint — on-device scale

0.99 / 0.39
pii-screen F1: solved ≥1.7B, collapses at 0.6B

⚠️ The lift compares different metrics and sample sizes (comparator strict-span vs a 50-sample training eval) — it's directional, not a measured head-to-head.

> **Honest status:** 2 runs complete, 1 running, **7 failed** (the whole pseudonymization group failed at step 0); no fine-tuned model benchmarked head-to-head yet. **Next:** run the adapters through the comparator on the same datasets/metrics — the first real head-to-head.

Build privacy in by default.

	Opt-out by default	no training on personal chats unless clearly opted in [5]
	Zero retention	short, transparent retention; “delete” that deletes [8]
	Data minimization	don’t log or keep what the task doesn’t need
	On-device / confidential compute	do sensitive work where the provider can’t read it [28] [27]
	Scoped agents	tools get the narrowest access, not the keys [15]
	Transparency	show what’s stored, for how long, and who can see it

Today most of these ship only in enterprise tiers or as buried opt-outs — consumer defaults still train by default. The defaults are the policy: privacy shouldn’t require the paid plan.

[5] Anthropic terms [8] OpenAI v. NYT [15] Agent injection ’25 [27] Conf. compute ’24 [28] Apple PCC

Where the law stands.

EU · GDPR & AI Act	access, deletion, consent with teeth — Italy fined OpenAI €15M [17] [31]
India · DPDP	passed 2023; rules notified 2025, phased into 2027 [32]
South Korea · PIPA	the PIPC fined Scatter Lab over Lee Luda — and now polices AI [33]
US · patchwork	CCPA/CPRA only; HIPAA covers hospitals, not your chatbot

Rights exist on paper; enforcement lags, and "delete" rarely reaches backups, logs, or training sets.

[17] Garante €15M '24 [31] EU AI Act [32] India DPDP [33] Korea PIPA

A defined problem — an open solution space.

As systems move from chat to agents, the exposure surface outpaces both habits and regulation.

The motivation is empirical; the methods are immature. An invitation to the community — to build the benchmarks, defenses, and systems that make private prompting real.

THE PROBLEM

well-defined · empirically grounded

THE SOLUTIONS

OPEN — WHERE THE WORK IS

methods immature

What a week of prompts reveals.

“fasting glucose came back 141. i’m 31 — is this diabetes, or am i overthinking?”	health · 1:14 AM
“rewrite this slack to my lead — i need one more day but don’t want to sound like i’m slipping.”	work · cover
“my parents think Naver means i made it. how do i say i might leave for a startup?”	a plan he’s hiding
“is it normal to feel lonely even when i’m around people all day?”	a quiet admission
“my rent is ₩1.45M next week and my card payment bounced. what should i pay first?”	a fear · money

Free text carries intent, fears, plans, and identifiers — and models readily re-link “anonymous” prompts to one person.[25][22]

But surely…?

“I’ve nothing to hide”	Privacy isn’t secrecy. “Nothing to hide” lasts right up until a prompt is used against you — for a job, a loan, a visa, or in court.
“It’s anonymised”	Removing the name is the easy part — city, employer, condition and dates still point to one person; LLMs are built to re-link “anonymous” text. [25]
“It’s encrypted”	In transit only — the provider decrypts it to read, log, and train.
“It’s already out there”	Your socials are curated by choice; prompts are candid and involuntary — and they link your public profile to everything you’d never post.
“I delete my chats”	Deletion is often incomplete — a court has ordered chats kept even after you delete them, and training copies persist. [8]
“I trust the provider”	Trust doesn’t survive a breach, an insider, a policy change, a subpoena, or an acquisition.

“The convenience is worth it” — maybe. But you can keep the convenience and cut the exposure.

[8] OpenAI v. NYT [25] ACL ’25, re-link

What you can do today.

Turn off training	disable history, or use enterprise / zero-retention tiers
Don’t paste secrets	no credentials, no whole documents, no other people’s data
Scrub before you paste	strip PII, or run a local pre-processor
Keep the crown jewels local	use an on-device model for the sensitive work
Prune memory	clear it; use temporary chats for one-off questions
Assume it’s logged	if you wouldn’t email it to a stranger, don’t prompt it

Small habits, big drop in exposure — you don’t have to quit AI.

References.

[1] ChatGPT WAU ’26

[2] 2.5B prompts/day

[3] Cyberhaven ’25

[4] Shadow-AI ’25

[5] Anthropic terms

[6] Wiz 38TB ’23

[7] EchoLeak ’25

[8] OpenAI v. NYT

[9] Nasr et al. ’23

[10] Lee Luda ’21

[11] Redis bug, OpenAI ’23

[12] Samsung ban ’23

[13] DeepSeek leak ’25

[14] AgentFlayer ’25

[15] Agent injection ’25

[16] PrivacyBench ’25

References.

[17] Garante €15M ’24
[18] IBM breach ’25
[19] OpenAI 20M logs
[20] Gemini privacy
[21] Akkus, USENIX ’25
[22] CAPRI, IEEE ’25
[23] CamoLeak ’25
[24] Edemacu survey ’25
[25] ACL ’25, re-link
[26] Preempt ’25
[27] Conf. compute ’24
[28] Apple PCC
[29] Rescriber, CHI ’25
[30] Retrieval privacy ’25
[31] EU AI Act
[32] India DPDP

References.

[33] Korea PIPA

[34] ai4privacy — pii-masking-300k dataset · huggingface.co

[35] NVIDIA Nemotron-PII — synthetic PII/PHI dataset · huggingface.co

[36] Casper — prompt-sanitization browser gatekeeper (Chong et al.), 2024 · arXiv:2408.07004

[37] “Guarding Your Conversations” — LLM privacy gatekeepers (Uzor et al.), 2025 · arXiv:2508.16765

[38] NVIDIA GLiNER-PII — span PII/PHI detector, 55+ categories · huggingface.co

[39] Microsoft Presidio — open-source PII detection & anonymization · github.com

[40] ProSan — “The Fire Thief Is Also the Keeper” prompt sanitizer (Shen et al.), 2024 · arXiv:2406.14318

[41] PromptGraph — graph-guided prompt sanitization, 2026 · arXiv:2607.10709

[42] QLoRA — efficient finetuning of quantized LLMs (Dettmers et al.), 2023 · arXiv:2305.14314